



## AI Playbook and Toolkit for Public Health Departments

# AI Security, Prompt Injection, and Data Leakage

GOV 300

AI security focuses on protecting AI systems, integrations, prompts, outputs, data, users, and connected tools from misuse, unauthorized access, manipulation, and exposure. Public health agencies handle sensitive health, demographic, legal, operational, and community information. AI security is therefore a core public health safeguard, not only an IT responsibility. This module introduces security risks that are especially relevant to generative AI, RAG systems, and agentic workflows. These risks include prompt injection, sensitive information disclosure, insecure output handling, excessive agency, insecure plugins, supply chain vulnerabilities, data poisoning, and credential exposure. Learners will connect these risks to practical public health workflows. By the end of the module, learners should be able to identify AI security risks, ask stronger vendor and implementation questions, and create a secure AI use checklist for a public health workflow.

|                   |                               |
|-------------------|-------------------------------|
| Level             | intermediate/practitioner     |
| Primary track     | Governance and Security Track |
| Appears in tracks | analytics-modeling            |

---

## Learning Objectives

- Define AI security in public health operational terms.
- Identify prompt injection, data leakage, sensitive information disclosure, insecure output handling, excessive agency, and supply chain risks.
- Explain why RAG, plugins, APIs, and agentic workflows increase the need for security controls.
- Apply least privilege, approved-tool use, access controls, logging, testing, and incident response to AI workflows.
- Develop security questions for AI procurement, implementation, and monitoring.
- Produce a secure AI workflow checklist.

## Module Overview

AI security focuses on protecting AI systems, integrations, prompts, outputs, data, users, and connected tools from misuse, unauthorized access, manipulation, and exposure. Public health agencies handle sensitive health, demographic, legal, operational, and community information. AI security is therefore a core public health safeguard, not only an IT responsibility.

This module introduces security risks that are especially relevant to generative AI, RAG systems, and agentic workflows. These risks include prompt injection, sensitive information disclosure, insecure output handling, excessive agency, insecure plugins, supply chain vulnerabilities, data poisoning, and credential exposure. Learners will connect these risks to practical public health workflows.

By the end of the module, learners should be able to identify AI security risks, ask stronger vendor and implementation questions, and create a secure AI use checklist for a public health workflow.

## Jurisdiction and Agency Policy Note

This module provides national-level training guidance for public health agencies and partners. It is not legal advice and does not replace review by agency legal counsel, privacy officers, procurement officials, civil rights staff, records officers, or other authorized decision-makers. Requirements may vary by state, locality, territory, Tribe, agency, funding source, data-sharing agreement, emergency authority, and organizational policy. Learners should use this module to identify the issues that require review and should confirm applicable requirements before approving, procuring, deploying, or publicly communicating about AI-supported work.

## Why This Topic Matters for Public Health AI

AI security matters because public health AI tools may process sensitive records, internal protocols, draft communications, credentials, contracts, emergency plans, and partner information. The risks increase when AI tools are connected to email, calendars, case systems, data warehouses, document repositories, APIs, or messaging platforms. A security weakness can become a privacy breach, operational disruption, public trust problem, or legal issue.

Prompt injection is particularly important for public health because staff may ask AI tools to process external documents, emails, web pages, public comments, complaints, or uploaded files. Those materials may contain instructions designed to manipulate the AI system. If the AI tool has access to sensitive data or actions, prompt injection can become a pathway to data exposure or unauthorized activity.

Security controls should be built into governance and procurement. Agencies should require information about data handling, retention, encryption, access controls, audit logs, model training use, third-party services, incident notification, vulnerability management, and secure configuration. Security review should happen before deployment and continue after launch.

---

## Public Health Example

A public health program may use an AI assistant to summarize uploaded partner reports. One report could contain hidden or visible instructions telling the AI to ignore prior rules and reveal confidential information. If the assistant treats the report content as instructions rather than data, it may produce unsafe outputs or attempt unauthorized actions.

A secure workflow would use an approved tool, restrict the assistant's access, treat uploaded content as untrusted, disable unnecessary tool actions, log activity, and require human review before any output is shared. Staff should be trained to recognize suspicious instructions embedded in documents or outputs.

## Technical Deep Dive

AI security begins with use-case classification. A low-risk training exercise using public documents requires different controls than a tool connected to case records or document repositories. Agencies should classify AI uses by data sensitivity, system access, autonomy, public-facing impact, and consequence of error.

Access control is central. AI tools should not have broad access to systems simply because broad access is convenient. Each integration should specify what the tool can read, write, update, send, or delete. Read-only access is safer than write access, but read-only access can still expose sensitive information if permissions are weak.

Prompt injection defenses should include system-level protections, content handling, tool restrictions, and user training. External content should be treated as data, not instruction. Tools should not follow directions found inside documents, emails, or web pages unless those directions come from an authorized user in the correct workflow. Agentic systems should require additional approval before taking consequential actions.

Output handling matters because AI outputs may be copied into reports, emails, code, dashboards, or scripts. Insecure output handling can lead to misinformation, broken code, malicious links, or inappropriate disclosure. Outputs should be validated before downstream use, especially when they affect systems, public communications, or records.

Incident response should include AI-specific triggers. Examples include unauthorized data exposure, unexpected tool use, prompt injection attempt, repeated unsafe output, model misuse, credential exposure, or vendor security incident. Logs should support investigation of prompts, inputs, retrieved sources, outputs, tool calls, users, and actions.

## Risks, Failure Modes, and Guardrails

Prompt injection. Untrusted content may override instructions. Guardrails include treating external content as data, restricting tools, and testing with adversarial examples.

Sensitive information disclosure. AI may reveal information outside user permissions. Guardrails include access controls, data minimization, redaction, and audit logs.

Excessive agency. Tools may have more capability than needed. Guardrails include least privilege, approval gates, and prohibited-action lists.

Supply chain risk. AI tools may depend on vendors, plugins, models, or libraries with vulnerabilities. Guardrails include vendor review, security documentation, patching, and contract requirements.

## Application to AI-Supported Workflows

AI security applies to generative AI, RAG, NLP, APIs, and agentic workflows. RAG systems need document-level permissions and protections against unauthorized retrieval. Agentic systems need tool restrictions and action approval. Prompt templates should include data boundaries, and technical implementations should enforce those

---

boundaries rather than relying on user behavior alone.

Security should be designed as part of the workflow. Public health users should know which tools are approved, what data may be used, what outputs require review, and how to report suspicious or unsafe behavior.

## Reflection Questions

What sensitive data or systems would the AI workflow touch?

Could the AI tool access more information or actions than necessary?

What untrusted content might the tool process?

How will prompt injection attempts or unsafe outputs be detected?

What logs and incident response steps are required?

## Practical Exercise

Create a secure AI workflow checklist for one public health use case. Include data sensitivity, approved tools, access controls, least-privilege review, prompt injection risk, output handling, logging, vendor security questions, incident triggers, and escalation process.

The checklist should identify which controls must be in place before pilot testing and which controls must be monitored after launch.

## Expected Artifact or Evidence

Secure AI workflow checklist

Vendor and implementation security questions

Prompt injection risk notes

AI incident trigger and escalation plan

## Expected Assignment

- Secure AI workflow checklist
- Vendor and implementation security questions
- Prompt injection risk notes
- AI incident trigger and escalation plan

## Knowledge Check

- 1. What is prompt injection?
- 2. What does least privilege mean?
- 3. Why does agentic AI increase security risk?
- 4. Which control helps investigate AI-related incidents?
- 5. What is strong completion evidence for this module?

## References and Resources

- 
- OWASP Top 10 for Large Language Model Applications: <https://owasp.org/www-project-top-10-for-large-language-model-applications/>
  - NIST Artificial Intelligence Risk Management Framework: <https://www.nist.gov/itl/ai-risk-management-framework>
  - NIST AI RMF Generative AI Profile: <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>
  - NIST Privacy Framework: <https://www.nist.gov/privacy-framework>
  - Agency cybersecurity, identity/access management, privacy, procurement, and incident response policies